

Riesgo	Probabilidad	Impacto	Nivel de prioridad	Control propuesto	Requisito/funcionalidad relacionada	Justificación técnica
Acceso no autorizado	Alta	Alta	Crítico	Implementar autenticación multifactor (MFA) y control de acceso basado en roles (RBAC)	Módulo de autenticación y autorización	Verifica la identidad del usuario mediante múltiples factores y limita el acceso a funciones según el rol asignado, reduciendo significativamente la superficie de ataque
Fallos de autenticación o autorización	Alta	Alta	Crítico	Revisión mensual de roles y permisos; desactivación automática al rotar personal; auditoría de accesos	Panel de administración de usuarios y sistema de logging	Elimina permisos obsoletos que podrían ser explotados por personal que ya no debería tener acceso, garantizando el principio de mínimo privilegio
Falta de procedimiento de respuesta	Alta	Alta	Crítico	Documentar plan de respuesta a incidentes con flujo definido para notificar a HIPAA, pacientes y directivos, con plazos establecidos	Módulo de gestión de incidentes y compliance	Asegura cumplimiento legal (HIPAA) y transparencia, reduciendo el impacto legal y reputacional mediante una respuesta estructurada y oportuna
Validación deficiente de entradas	Media	Alta	Alto	Validación en servidor de todos los inputs, sanitización de datos y uso de expresiones regulares para formatos esperados	Todos los formularios, endpoints de API y capa de ingesta de datos	Previene la entrada de datos maliciosos que podrían comprometer la integridad del sistema o causar inyecciones, estableciendo una capa de defensa en el servidor
Exposición de datos sensibles	Media	Alta	Alto	Seudonimización de datos en capa de acceso (transformación de IDs en tokens), cifrado AES-256 en reposo y TLS 1.3 en tránsito	Módulo de acceso a datos, almacenamiento y comunicación entre módulos	Disminuye el riesgo de lectura no autorizada y deducción de identidad de pacientes; el cifrado protege los datos incluso si el almacenamiento o la transmisión son comprometidos

Inyección de código	Baja	Alta	Alto	Uso de consultas parametrizadas, ORM y sanitización de entradas; revisión de código enfocada en inyecciones	Capa de acceso a base de datos y todos los endpoints que reciben input	Evita la ejecución de código malicioso a través de inputs del sistema al separar datos de comandos, eliminando el vector de ataque más común para inyecciones SQL y NoSQL
---------------------	------	------	------	---	--	---